



Audit Summary Report — ISO/IEC 27001:2022 & NIST CSF v1.1

Rapporto Finale di Sintesi dell'Audit d'Insieme — Aetheris Therapeutics S.p.A.

Standard di Riferimento: ISO/IEC 27001:2022, ISO 19011:2018 & NIST CSF v1.1

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: AUD-SUM-2026-03

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Per Uso Interno d'Audit

Data dell'Audit: 10 – 14 Agosto 2026

1. Dati Generali e Scopo dell'Audit

- **Cliente dell'Audit:** Board dell'Alta Direzione / CEO di Aetheris Therapeutics S.p.A.
- **Lead Auditor:** Emanuele Tarchi (*ISO/IEC 27001 Lead Auditor Trainee*)
- **Membri del Team d'Audit:** GRC Specialist Team
- **Perimetro dello SGSI (Scope):** Sistemi informativi, infrastruttura Cloud Azure/M365, reti di laboratorio R&D e processi di gestione dei dati clinici/PII presso la sede legale e i laboratori centrali.
- **Obiettivo dell'Audit:** Valutare lo stato di conformità dello SGSI ai requisiti delle Clausole 4–10 di ISO 27001:2022, la copertura dei controlli dell'Annex A e misurare la maturità sui domini del NIST Cybersecurity Framework v1.1.

2. Conclusioni Generali dell'Auditor & Giudizio Finale

In conformità alla norma **ISO 19011:2018**, a seguito del fieldwork condotto dal 10 al 14 Agosto 2026, il Lead Auditor esprime la seguente valutazione ufficiale:



ESITO DELL'AUDIT: SISTEMA NON PRONTO PER LA CERTIFICAZIONE (FAIL / STAGE 1 NOT RECOMMENDED)

Lo Sistema di Gestione della Sicurezza dell'Informazione (SGSI) di Aetheris Therapeutics S.p.A. presenta buone basi infrastrutturali di protezione perimetrale e fisica, ma soffre di **gravi e sistemiche carenze di Governance, Risk Management e Incident Response**.

La presenza di **5 Non-Conformità Maggiori (NC Major)** preclude il superamento di un eventuale Audit di Certificazione ufficiale (Stage 1 / Stage 2). Si richiede l'esecuzione immediata del Risk Treatment Plan (RTP) approvato per colmare i gap riscontrati.

3. Ripartizione Statistica dei Rilievi d'Audit

Tipologia di Rilievo (ISO 19011)	Quantità	Impatto sul Sistema di Gestione (SGSI)
Non-Conformità Maggiori (NC Major)	5	Bloccanti: Mancanza di requisiti essenziali (MFA, PAM, IRP, SIEM, GDPR).
Non-Conformità Minori (NC Minor)	4	Parziali: Inadempienze procedurali (ITAM manuale, Asset Owner, Supplier Contract).
Opportunità di Miglioramento (OFI)	3	Raccomandazioni: EDR comportamentale, Awareness Phishing, DLP Enforce.
Controlli Conformi (PASS)	4	Conformi: Segmentazione VLAN, Backup cifrati immutabili, Badge fisici, DR Test.
TOTALE RILIEVI ARCHIVIATI	16	Copertura totale delle aree di perimetro dell'Audit.

4. Sintesi dei Rilievi per Clausola ISO 27001 & Domini NIST

4.1 Valutazione sulle Clausole Obbligatorie ISO 27001 (4–10)

- **Clausola 4 (Contesto):** *Conforme*. Comprensione delle esigenze delle parti interessate e definizione dello Scope completate.
- **Clausola 5 (Leadership):** *Non Conforme (Minor)*. Manca la formalizzazione delle responsabilità specifiche per la sicurezza delle informazioni (ISMS Owner).
- **Clausola 6 (Pianificazione):** *Non Conforme (Major)*. Valutazione dei rischi eseguita, ma assenza di un Risk Treatment Plan (RTP) formale e approvato.
- **Clausola 7 (Supporto):** *Non Conforme (Minor)*. Mancanza di programmi di formazione e consapevolezza (Awareness) periodici.
- **Clausola 8 (Attività Operative):** *Non Conforme (Major)*. Assenza di procedure gestite per la risposta agli incidenti (Incident Response) e per il controllo degli accessi privilegiati.
- **Clausola 9 (Valutazione delle Prestazioni):** *Non Conforme (Major)*. Assenza di monitoraggio log centralizzato (SIEM) e mancata esecuzione di Internal Audit (ISO 19011).
- **Clausola 10 (Miglioramento):** *In Corso*. Attivazione del processo CAPA per la gestione dei rilievi emersi nel presente audit.

4.2 Sintesi di Conformità dell'Annex A (93 Controlli)

Categoria Controlli Annex A	Controlli Valutati	Conformi (PASS)	Non Conformi (NC)	% Conformità
A.5 Controlli Organizzativi	37	1	36	2.7%
A.6 Controlli sul Personale	8	0	8	0.0%
A.7 Controlli Fisici	14	1	13	7.1%
A.8 Controlli Tecnologici	34	2	32	5.8%

5. Raccomandazioni d'Audit e Prossimi Passi (Next Steps)

1. **Adozione del Risk Treatment Plan (RTP):** L'Alta Direzione deve approvare formalmente il piano di remediation (RSK-RTP-2026-03) e allocare il budget straordinario di € 70.000.
2. **Priorità Fase 1 (Entro 90 giorni):**
 3. Implementazione immediata dell'MFA sulle connessioni VPN Palo Alto.
 4. Dismissione degli account Domain Admin generici e adozione di utenze nominali.
 5. Redazione e formalizzazione del Registro dei Trattamenti (Art. 30 GDPR).
 6. Stesura dell'Incident Response Plan (IRP) e costituzione del CIRT.
7. **Pianificazione Re-Audit:** Sulla base dell'avanzamento dei lavori di remediation, si raccomanda l'esecuzione di un **Follow-up Audit / Internal Audit (ISO 19011) a Maggio 2027** per la verifica della chiusura di tutte le Non-Conformità.

6. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	14 Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	16 Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	18 Agosto 2026